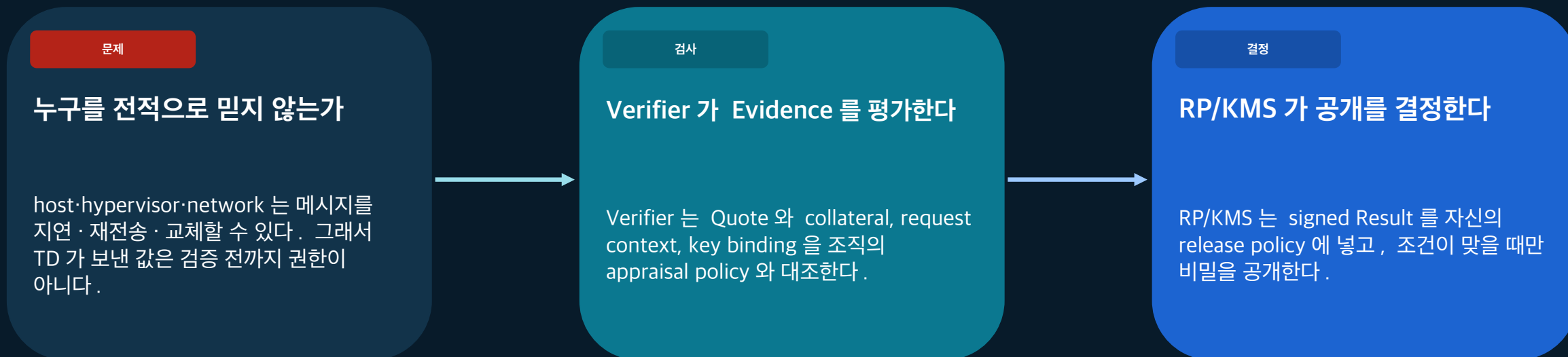


Intel TDX 원격 증명은 승인한 VM에만 비밀을 공개하는 통제다

01

클라우드 운영자를 전적으로 믿지 않아도, hardware Evidence 와 조직 policy 가 함께 secret release 를 조건화한다.



읽는 문장

즉, Quote 가 유효하다는 사실은 Verifier 의 appraisal 결과일 뿐이다. 비밀을 공개할 권한은 Result 를 검증한 RP/KMS 의 별도 정책에서 나온다.

같은 경로에 있어도 같은 trust role 은 아니다

02

역할을 분리하면 “누가 무엇을 만들고, 누가 무엇을 믿으며, 누가 행동을 결정하는지”가 보인다.

TD

TDX 가 보호하는 VM

임시 키를 만들고 TDREPORT 를 요청한다.

QGS

host-side transport

TDREPORT·Quote 를 운반하지만 accepted Quote 를 서명하지 못한다.

TDQE

Quoting Enclave

같은 플랫폼 TDREPORT 를 확인하고 TD Quote 에 서명한다.

Verifier

증거 평가자

nonce 를 보관하고 Evidence 를 검증·평가해 Result 를 서명한다.

RP/KMS

공개 결정자

Result 를 확인하고 secret release policy 를 집행한다.

PCS/PCCS

authority / cache

PCS 서명은 검증하고 PCCS cache 자체는 권위로 믿지 않는다.

구분 규칙

QGS 가 Quote generation 을 조율해도 signer 는 TDQE 다. Verifier 가 Result 를 서명해도 secret 을 공개하는 owner 는 RP/KMS 다.

공격 가능한 경로는 Evidence 를 운반할 수 있어도 권한을 만들 수는 없다

03

host·network·QGS·PCCS·Attester input 을 검증 전까지 신뢰하지 않는 위협 모델에서 시작한다 .

공격자가 할 수 있는 일

drop · delay · replay · reorder · substitute ·
deny service

신뢰하는 기반

CPU/TDX Module · TDQE/PCK chain · PCS
signatures · Verifier policy/key · RP/KMS
policy/time

보장하지 않는 것

availability · code correctness · future
behavior · 모든 side-channel · protected
external I/O

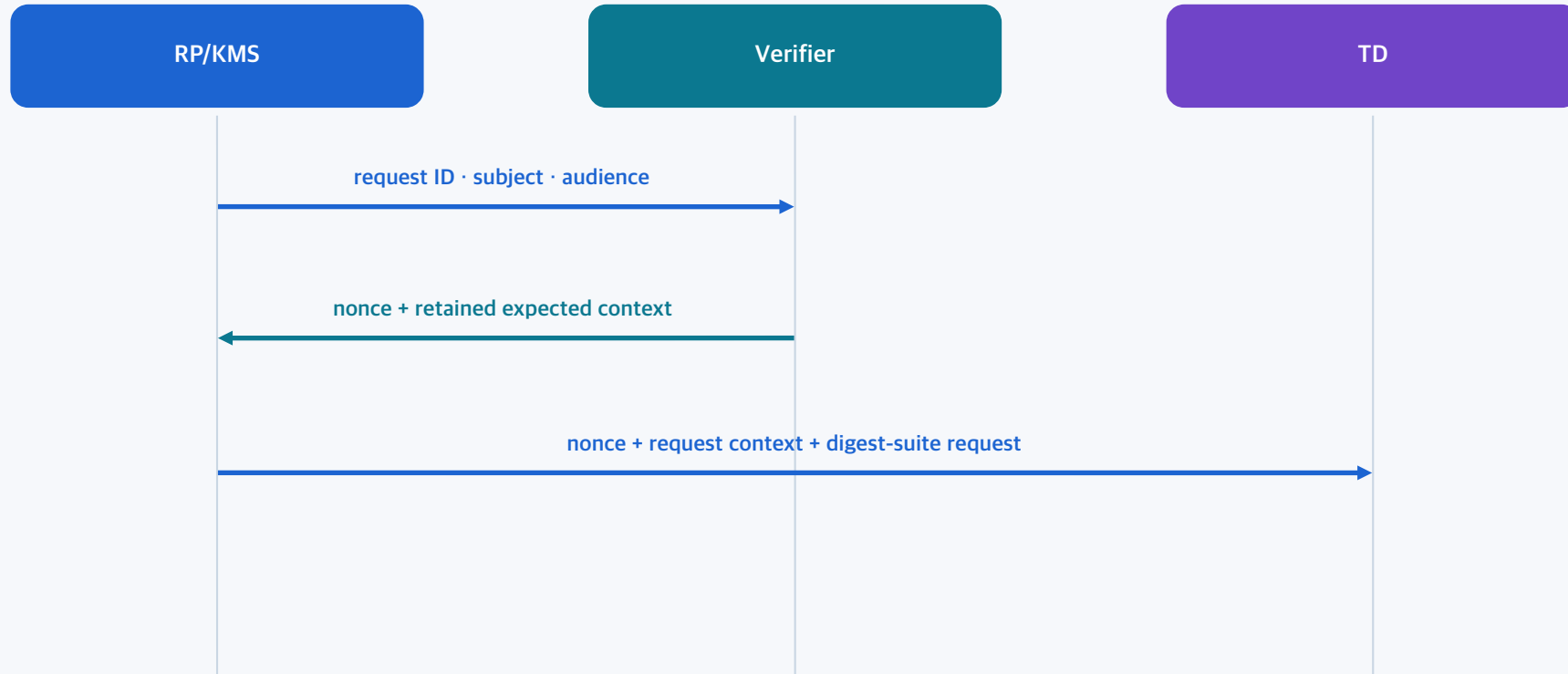
경계의 의미

untrusted path 가 Quote 를 재전송하거나 바꿔도 , Verifier 는 retained nonce·request·key binding 을 다시 비교한다 . 비교에 실패하거나 입력이 오래되면 policy 는 fail closed 또는 명시된 제한 정책으로 처리한다 .

nonce 는 “이 Quote 가 지금 이 요청을 위한 것인가”를 확인하는 일회용 기준이다

04

Verifier 가 기대 문맥을 보관하고 , RP/KMS 가 그 문맥을 TD 까지 전달해야 replay 와 substitution 을 거부할 수 있다 .



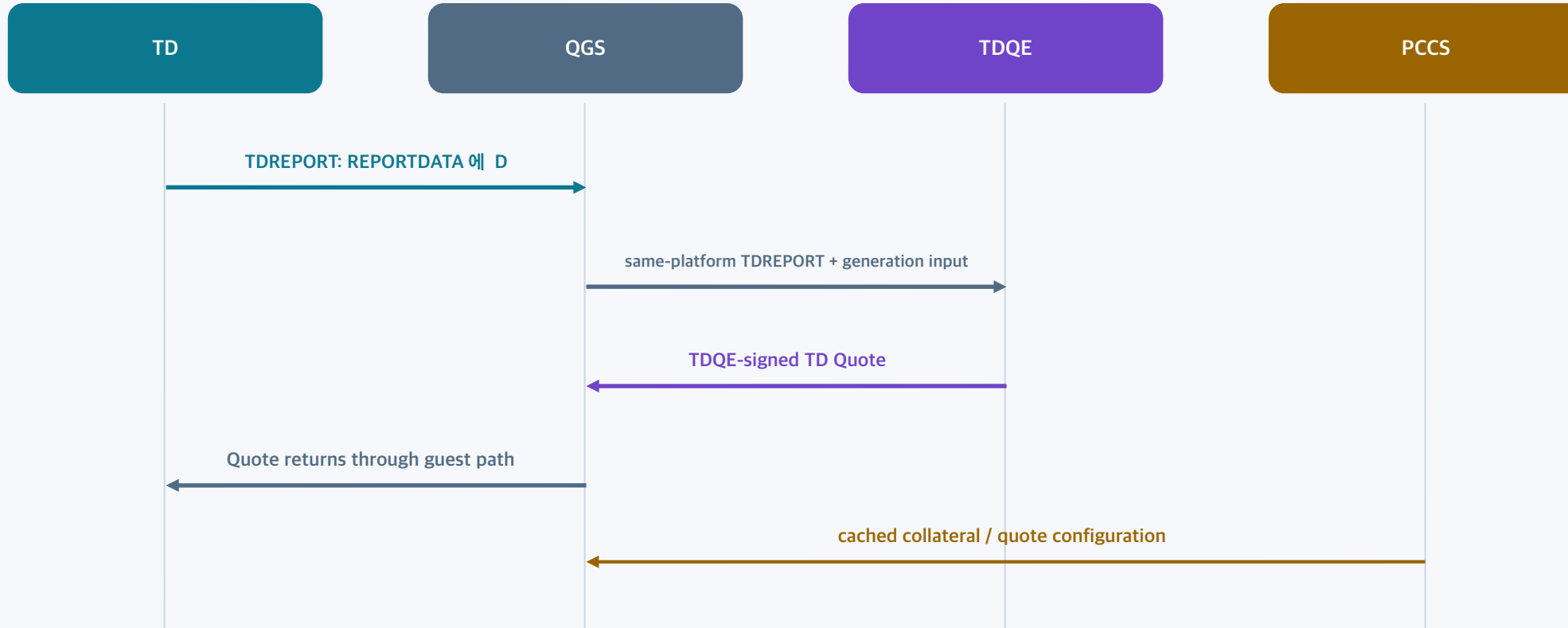
읽는 문장

Verifier 가 nonce 를 만들고 terminal state 까지 보관한다 . TD 는 그 nonce 와 request context 를 D 에 묶고 , Verifier 는 나중에 같은 값을 재계산해 이 Evidence 가 다른 요청에서 온 것이 아닌지 확인한다 .

QGS 는 운반하고 TDQE 가 서명한다

05

Quote generation path 에서 transport 성공과 signing authority 를 분리해야 host-side daemon 을 과신하지 않는다 .



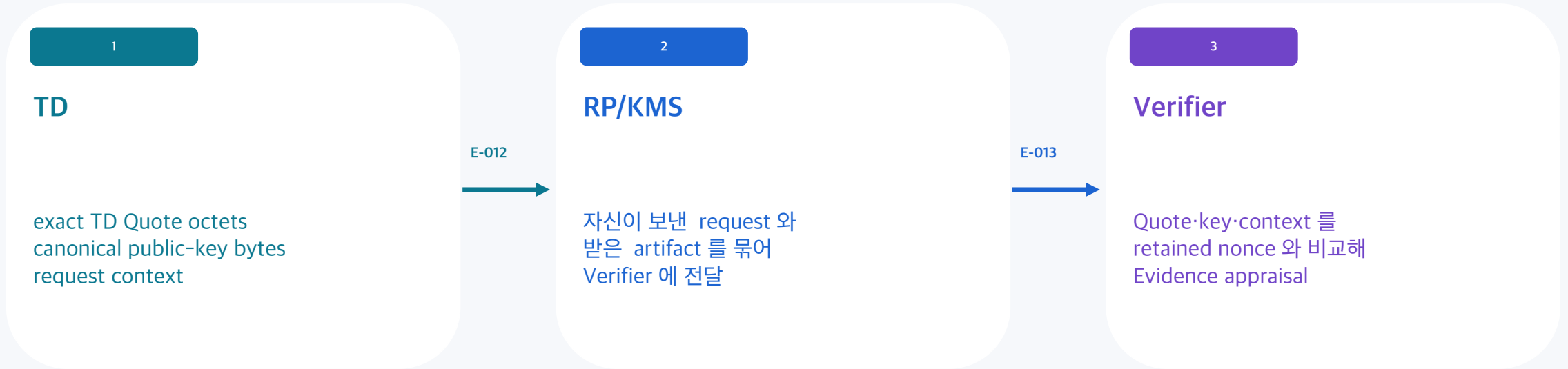
읽는 문장

TD 는 TDREPORT 를 QGS 에 넘기지만 , QGS 가 받은 report 에 신뢰를 더하지는 않는다 . TDQE 가 같은 platform report 를 확인하고 Quote 를 서명하며 , Verifier 는 나중에 그 Quote 와 collateral 을 별도로 검증한다 .

TD 가 만든 Quote 와 key bytes 는 RP/KMS 를 거쳐 Verifier 의 appraisal 로 들어간다

06

이 transport route 를 분명히 하면 QGS 의 guest path 와 Evidence delivery path 를 혼동하지 않는다 .



E-012 → E-013

RP/KMS 가 TD 에서 받은 exact Quote, canonical key bytes, identical request context 를 Verifier 에 전달한다 . Verifier 는 보관한 expected context 와 비교해 Evidence 가 이 request 와 이 key 를 위한 것인지 판단한다 .

K, D, E 는 “무엇을 확인했는가”를 세 종류의 bytes 에 묶는다

07

이 식은 RFC wire format 이 아니라 deployment 가 hash·encoding·field order 를 확정해야 하는 symbolic profile 이다 .

K

canonical public-key bytes 의 digest

어느 public key 가 나중에 secret 을 받을 수 있는지 묶는다 .

D

nonce + request + subject + audience + K 의 digest

TD 가 REPORTDATA 에 넣어 request context 와 key 를 TDREPORT 에 묶는다 .

E

exact TD Quote octets 의 digest

Result 가 어떤 Quote Evidence 를 평가한 결과인지 RP/KMS 가 확인하게 한다 .

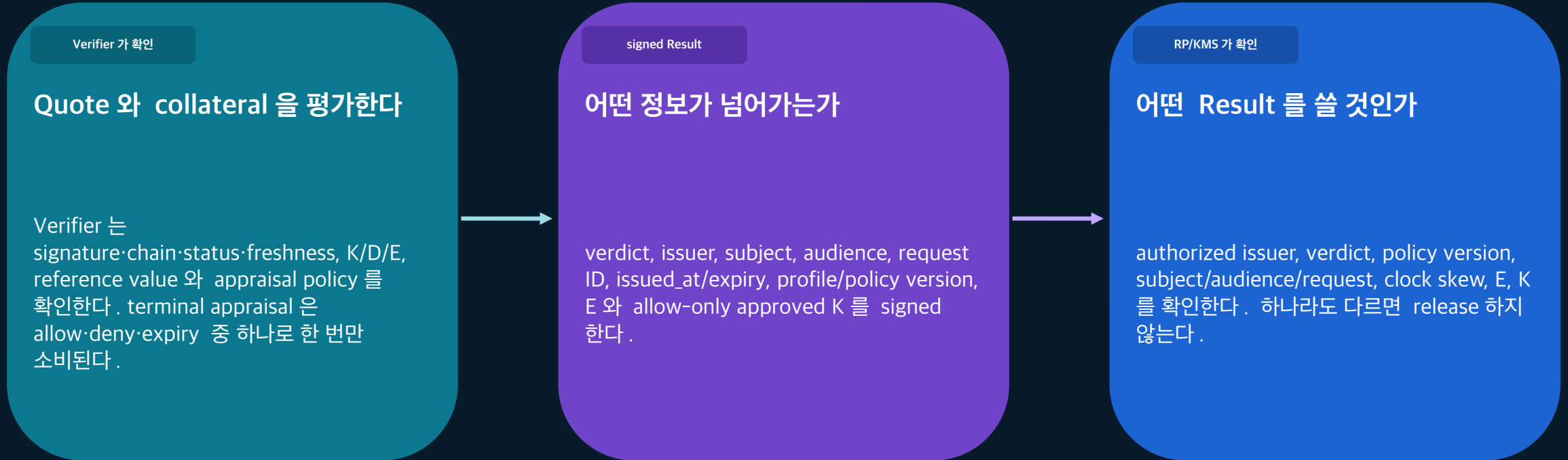
비교 규칙

Verifier 는 retained nonce 와 받은 context·key bytes 로 K 와 D 를 재계산해 REPORTDATA 와 비교하고 , exact Quote bytes 로 E 를 계산한다 . 이 비교가 맞아야 Result 의 verdict 와 approved K 가 같은 request/Evidence 를 가리킨다 .

Verifier Result 는 평가의 서명된 기록이고 , 비밀 공개 명령은 아니다

08

Result 에는 verdict 뿐 아니라 request·policy version·E·allow-only K 가 들어가 RP/KMS 가 무엇을 승인하는지 다시 확인할 수 있어야 한다 .



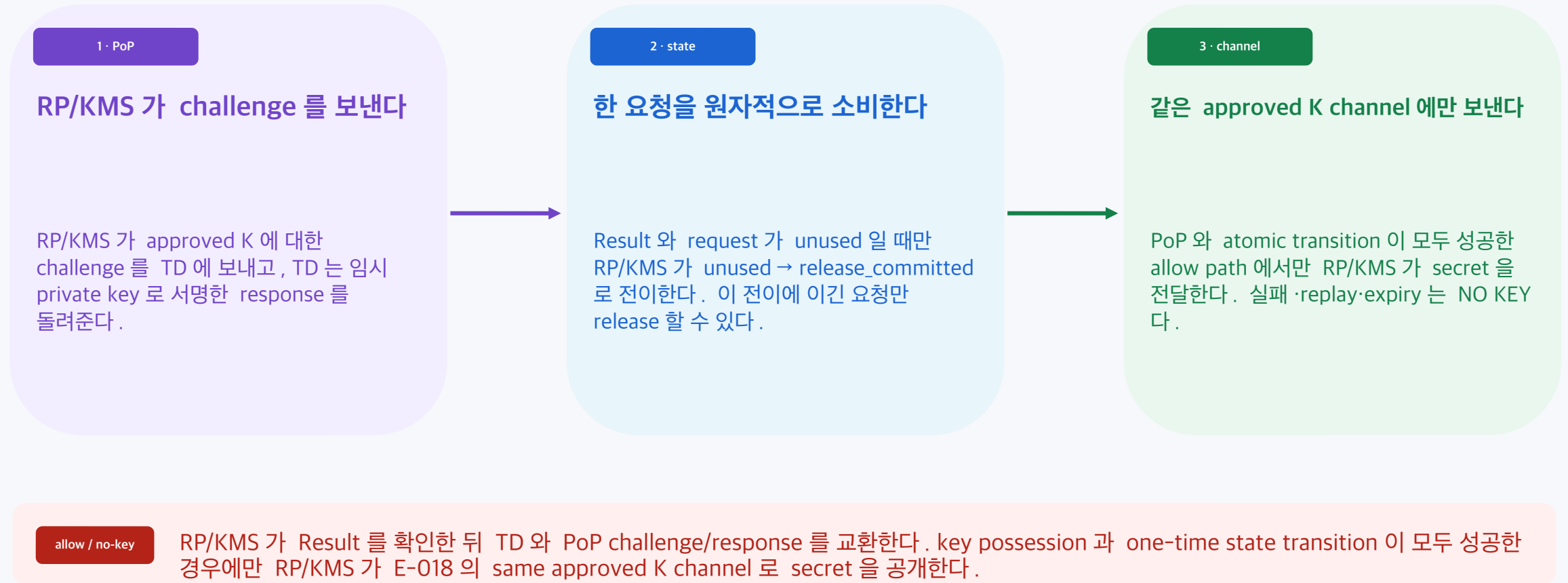
읽는 문장

Verifier 가 signed Result 를 RP/KMS 에 보낸다 . RP/KMS 는 Result signature 와 policy/time/E/K 를 확인하지만 , 그 확인 자체를 secret release 로 취급하지 않고 다음 PoP·state transition 단계까지 진행한다 .

비밀 공개는 PoP 와 일회용 state 가 통과한 뒤 한 번만 수행한다

09

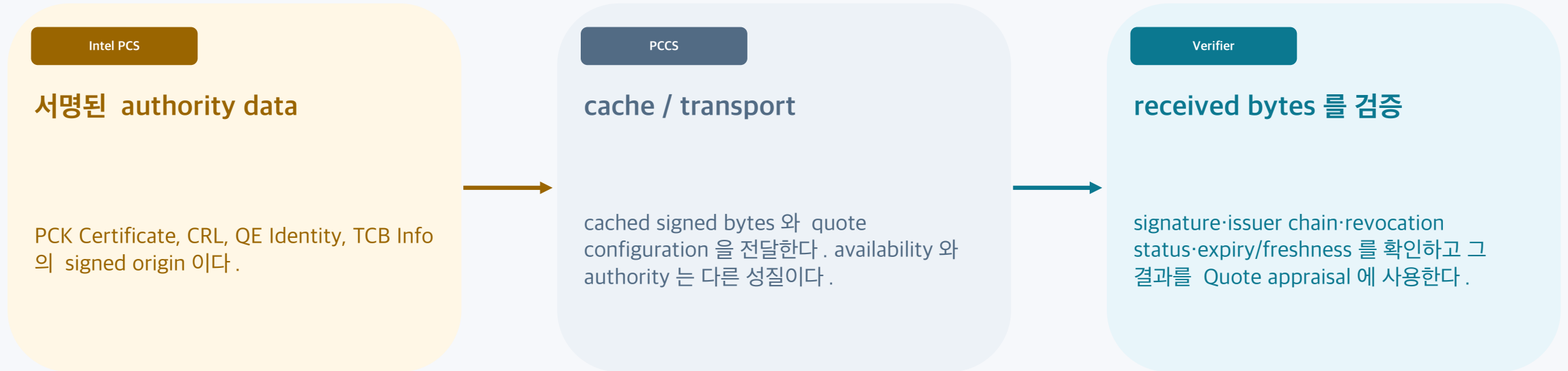
Result 가 allow 여도 RP/KMS 는 approved K 의 private key 를 실제로 가진 TD 인지 확인하고 replay 를 막아야 한다 .



PCCS 가 살아 있다는 사실이 collateral 이 유효하다는 뜻은 아니다

10

PCS 는 signed authority data 의 원천이고 PCCS 는 cache/transport 이므로 , Verifier 는 받은 bytes 자체를 검증한다 .



운영 결과

PCCS outage, nextUpdate 실패 , revocation, TCB 변경은 운영 policy 가 처리해야 한다 . Verifier 는 PCCS cache 를 믿어서가 아니라 received collateral 의 cryptographic validity 와 freshness 를 확인해서만 사용한다 .

Quote 는 TD 가 보고한 상태를 보여 주지만 workload 의 모든 성질을 증명하지는 않는다

11

proof boundary 를 분리해야 valid Quote 를 code correctness 나 container identity 로 과대 해석하지 않는다 .

이 경로로 알 수 있는 것

- Quote integrity 와 accepted quoting credential 연결
- reported TD measurement·attribute·TCB state
- D 가 retained context 와 canonical key 에 묶였는지
- Result 가 E·policy version·allow-only K 를 가리키는지

Quote 만으로는 알 수 없는 것

- code correctness 또는 vulnerability absence
- TD 안의 container/process 자동 identity
- attestation 이후의 future-safe behavior
- availability 와 모든 side-channel·I/O·physical·supply-chain risk 제거

설계 판단

Quote 검증은 workload correctness 나 container identity 를 증명하지 않는다 . 그것이 release 조건이면 workload Evidence 와 runtime control 을 별도로 추가한다 .

Intel-rats 는 판단 구조를 배우는 학습 자료이지 운영 verifier 기준은 아니다

12

프로젝트는 도메인 판단 구조와 설계 검토 질문을 보이게 하지만 production implementation 을 보증하지는 않는다 .

취할 강점

도메인 구조를 보이게 한다

TD·Guest Agent·Verifier·Key Broker·PCS/PCCS·policy owner 를 하나의 release decision 으로 연결해 design review 질문을 만든다 .

고쳐 읽을 부분

표준 route 와 다를 수 있다

Background Check 과 aggregate graph 가 전달 패턴을 섞을 수 있다 .
nonce·audience·expiry·workload Evidence 는 first-class type 으로 보완해야 한다 .

사용 결론

학습과 설계 질문에는 사용한다

구현 ·security approval·runtime enforcement 의 단독 근거로 쓰지 않는다 . RFC 9334 와 current Intel TDX/DCAP documentation 으로 보완한다 .

reader question

Intel-rats 를 볼 때는 “누가 Evidence 를 평가하고 , 누가 release policy 를 소유하며 , 어떤 binding 과 failure state 가 explicit 한가”를 질문한다 . 답이 없는 부분은 실제 deployment 설계에서 추가해야 한다 .

TDX Quote 를 container identity 로 읽으면 증명 경계를 넘어선다

13

SGX 와 TDX 는 Evidence → appraisal → policy action 구조를 공유하지만 , attested scope 와 concrete mechanism 은 다르다 .

SGX

enclave identity 중심

SGX 는 MRENCLAVE·MRSIGNER 같은 enclave identity 를 중심으로 attestation 을 읽는다 . 그래도 code correctness 나 future safety 는 별도 문제다 .

TDX

whole Trust Domain / VM 경계 중심

TDX Quote 는 firmware·OS·workload 를 포함할 수 있는 TD 전체 VM state 를 보고한다 . TD 안의 개별 container 신원은 자동으로 나오지 않는다 .

scope limit

컨테이너가 준 값을 REPORTDATA 에 넣어도 컨테이너의 독립 identity 가 증명되는 것은 아니다 . protected identity 가 container 라면 workload-specific Evidence 와 policy check 를 별도로 설계한다 .

첫 파일럿은 회수 가능한 단일 key-release path 와 명확한 책임자에서 시작한다

14

출시 전에는 appraisal 과 release 의 책임자 , collateral 운영 , key binding, replay/expiry failure 를 수치 기준으로 확정한다 .

보안 · 플랫폼 책임자

reference values, TCB/freshness/binding appraisal policy, revocation/re-attestation 기준

보호 자산 서비스 책임자

Result-use/release policy, subject/audience/clock skew, fail-closed 운영 조건

플랫폼 운영

PCS/PCCS 갱신 , collateral outage posture, revocation-to-deny SLO, audit/recovery

개발자 · 아키텍트

challenge state machine, K/D/E suite, Result/PoP, negative tests, key rotation

출시 gate

첫 pilot 은 가치가 높고 회수 가능한 단일 key-release path 로 제한한다 . forged Quote·nonce replay·key substitution·Verifier/PCCS failure 에서 공개된 key 는 0 개여야 한다 .

Appendix: full Point claim · model · prose trace ledger

15

이 deck 은 10 claims, 8 nodes, 18 edges, 7 boundaries 와 context/state/proof/implication inventory 를 canonical Point hash 에 연결한다 .

Point claim	Reader-visible meaning	Primary slide(s)
C-001	release-control thesis	01
C-002	actors / trust roles	02, 05, 10
C-003	threat and trust assumptions	03, 04
C-004	closed Background Check path	04-09
C-005	PCS/PCCS collateral path	10
C-006	K/D/E + Result profile	07-09
C-007	proof / non-proof boundary	11
C-008	Intel-rats strengths / corrections	12
C-009	SGX vs TDX scope	13
C-010	owners and pilot	14

Exact object-level location, qualifiers, proof limits, implications, sources, and all N/E/B/X IDs: [final/structural-coverage-map.json](#) + [final/prose-trace.json](#)